PlusFund 2.1.5 Dev 反馈复核

审计对象： `RealeFinance/PlusFund`
最终复审提交： `b3a7fcf6e6fc643a0b34f061ca30c564e91ba8db`（2.1.5）
对照基线： `f1e810682a2f1b7608003f868007119a0bf6a8c9`（2.1.3）
Dev 反馈文档： `PlusFund-2.1.3-Astra-Security-Audit-Review.md`，对应整改工作区 `ee7e77c`（2.1.4 阶段）

结论

Dev 的反馈是有价值的。它澄清了资金托管、赎回费和黑名单权限等设计意图，也显示团队准确理解了多数原始问题。2.1.5 中确实存在实质修复，并非无效整改。

但该文档同时明确写有“待执行”“待决策”“待核验”的事项，而且没有覆盖 2.1.5 复审中新发现的两个发布问题。因此它能支持“修复方向基本合理”，不能支持“所有问题已经关闭，可以上线”。

当前结论保持：FAIL / PRODUCTION HOLD。剩余 0 Critical / 2 High / 2 Medium / 2 Low。

两项 High 均与旧代理实际状态有关。如果逐代理证据能够证明不存在受影响资产或订单，可以将对应项标记为不适用；在证据出现前，不能仅凭人工口头确认关闭。

对 Dev 各项回复的判断

原问题	Dev 回复带来的新信息	审计判断	当前状态
PF-01 默认自托管无法付款	明确不支持代理自托管，新部署使用外部多签；未配置时 fail-closed	新部署路径修复有效。但旧代理内已存在的支付资产不会因修改资金地址而转出，源码仍无 sweep、recover、approve 或迁移路径	**部分关闭，A215-01 High 保留**
PF-02 历史订单升级兼容	采用“升级前冻结并人工确认无 pending 订单”，不新增完整申购扫描工具	方案原则上成立，但尚无逐代理、固定区块、可复核的完整订单清单，也没有真实旧布局升级演练	**未关闭，A215-02 High 保留**
PF-03 provenance dust 队列填满	团队承认问题存在，尚未在产品取舍中选定方案	这是准确的风险接受讨论，不是技术修复。攻击者仍可阻断已付款用户的 claim 或合法入账	**未关闭，A215-03 Medium 保留**
PF-04 跨链 `tokenId=0`	合约拒绝零 ID，并有 2 项定向测试声明	2.1.5 源码中已实现原子拒绝，属于实质修复；历史损坏状态和真实 TokenPool 边界仍需单独核验	**新状态路径已修复**
PF-05 blacklist 权限无效	改为向 `blacklistAdmin` 授予 `PLUSFUND_ADMIN`，并明确这是完整业务管理员权限	解释证明这是有意设计，但该地址同时获得发行、结算、销毁、暂停等宽权限；第二个管理员地址没有与 `stokenAdmin` 相同的治理合约校验	**转化为明确治理风险，A215-04 Medium 保留**
PF-06 provider/explorer 值	当前配置迁移至 `.env`；项目方称 dRPC 为公开 endpoint	当前源码处理合理。若历史值确为公开 endpoint，可不按凭证泄露处理；账户专属值仍需服务所有者确认、撤销或轮换	**源码层面基本关闭，历史处置待证明**
PF-07 赎回服务费	业务明确取消赎回费，`claimUSD()` 全额付款	解释成立，赎回记录为 0 不再是缺陷。若仍宣称申购收费，需要指出实际链上或链下计算、收取和对账位置	**赎回费问题 N/A**
PF-08 升级脚本 initializer	主升级脚本改为显式开关，默认不调用 `initializeV2()`	主要问题已修复；但 `encode-data-update-2.js` 的 initializer 分支仍引用未定义的 `NewImplFactory`，启用时会失败	**主要路径已修，旁支脚本仍需修正**
PF-09 零金额转账	源码增加零额短路并发出 `Transfer`	源码逻辑成立；仍应在最终发布提交执行 EVM 回归	**源码已修，动态验证待完成**

2.1.5 复审中未被反馈覆盖的问题

A215-05 — Low：无效链下订单可永久占用 `offChainId`

2.1.5 新增 active ID 防重机制，但部分不可变字段可以在创建时保持无效值，直到完成阶段才被拒绝。由于没有 amend、cancel 或 release 路径，该业务 ID 会永久保持 active。应在占用 ID 前完成全部字段校验，并提供受权限控制的取消或更正机制。

A215-06 — Low：发布构建输入无法复现 2.1.5

仓库中的 `standard-input.json` 仍包含旧版源码和错误的 optimizer 设置。当前生成脚本忽略 PlusFund 的 per-file override，因此即使重新生成也未必对应真实发布字节码。应从 Hardhat 实际 build-info 导出标准输入，并把 commit、编译设置、runtime bytecode/hash、存储布局及部署地址绑定在同一发布证明中。

请 Dev 提供的最小关闭材料

1. A215-01：旧代理资产与负债

对每个拟升级代理，在同一固定区块提供：

- 代理地址、当前 implementation、`assetRecipient`、`assetSender`、`serviceFeeRecipient`；
- 每种支持支付代币在代理地址上的余额；
- 未付款申购/赎回负债及其对账结果；
- 若余额非零，提供经过测试并由治理批准的迁移/取回方案；若余额为零，提供可重复查询的链上证据。

2. A215-02：历史订单完整性

- 升级前冻结新订单的区块和时间；
- 完整枚举 pending subscription、pending redemption 和相关链下订单，而不只是赎回计数；
- 每条订单的最终结清或迁移状态；
- 使用真实旧实现、真实旧存储布局和代表性历史状态完成 UUPS 升级演练。

3. A215-03：dust 队列风险

提交已选择并实现的缓解方案，例如收款方 opt-in、重要业务预留容量、可验证的 lot 合并/清理机制，或其他等效设计。测试必须覆盖：队列满、已付款 claim、释放容量、攻击者重复填充以及 100 段消费上限。

4. A215-04：`blacklistAdmin` 权限治理

提供实际部署地址，并证明其为经批准的 Safe/Timelock，包括所有者、阈值和延迟。若继续共享完整 `PLUSFUND_ADMIN`，需书面接受该地址拥有发行、结算、销毁和暂停等全部权限；否则应拆分专用 blacklist role。

5. 发布验证

- 修复 A215-05、A215-06 和 `encode-data-update-2.js`；
- 在最终精确 commit 上执行完整 Hardhat/EVM 测试及 8 项审计回归；
- 对每个真实代理执行 OpenZeppelin `validateUpgrade` 和存储布局核验；
- 提交可复现 build-info、runtime bytecode/hash、代理 implementation slot、角色成员、Safe 阈值和 Timelock 延迟；
- 将“源码已修改”“测试已通过”“已部署”“生产状态已核验”分别给出证据，不应相互替代。

可重新评估 GO 的门槛

1. A215-01、A215-02 有逐代理证据关闭，或被可复核地证明为不适用；
2. A215-03 已实现缓解，或由有权主体书面接受且不会阻断关键 claim；
3. A215-04 权限边界收窄，或完成同等强度的治理约束与风险接受；
4. A215-05、A215-06 及剩余脚本缺陷已修复；
5. 最终发布提交通过动态测试、升级兼容、存储布局和可复现构建验证；
6. 部署后的实际代码、配置、角色和治理与审核材料一致。

在上述材料齐全前，建议继续保持 **PRODUCTION HOLD**。本复核为 AI 辅助安全审查，不替代专业第三方审计、法律意见或生产部署验收。